

Procedura obsługi incydentów bezpieczeństwa i incydentów operacyjnych

Bank Przykładowy S.A., BP/PRO/07, wersja 2, obowiązuje od 1 marca 2024 r. do 31 marca 2025 r.

Oznaczenie	BP/PRO/07
Wersja	2
Właściciel	Departament Bezpieczeństwa
Zatwierdził	Zarząd Banku Przykładowego S.A.
Data zatwierdzenia	9 lutego 2024 r.
Obowiązuje od	1 marca 2024 r.
Obowiązuje do	31 marca 2025 r.

Historia zmian

Wersja	Data	Opis zmian
1	11 października 2022 r.	Wydanie pierwsze.
2	9 lutego 2024 r.	Aktualizacja postanowień procedury.

1. Cel

Celem procedury jest zapewnienie jednolitego, szybkiego i udokumentowanego sposobu postępowania w przypadku wystąpienia w Banku incydentu bezpieczeństwa lub incydentu operacyjnego, tak aby zminimalizować jego skutki dla Klientów, ciągłości działania Banku i bezpieczeństwa chronionych informacji.

Procedura określa w szczególności:

- 1) źródła zgłoszeń o incydentach oraz sposób ich przyjmowania w Rejestrze;
- 2) zasady klasyfikacji incydentów i nadawania im poziomu ważności;
- 3) skład i zadania Zespołu oraz podział ról w trakcie obsługi incydentu;
- 4) działania mające na celu ograniczenie rozprzestrzeniania się incydentu i usunięcie jego przyczyn;
- 5) zasady komunikacji z Klientami, z organem nadzoru oraz z podmiotami zewnętrznymi;
- 6) terminy zgłaszania incydentów poważnych oraz naruszeń ochrony danych osobowych;
- 7) zabezpieczanie materiału dowodowego, przywracanie działania usług i przegląd po incydencie;
- 8) zasady testowania procedury i prowadzenia ćwiczeń.

Procedura służy także realizacji obowiązków Banku wynikających z przepisów o usługach płatniczych, Prawa bankowego oraz przepisów o ochronie danych osobowych, a także

wymogów organu nadzoru w zakresie zarządzania ryzyka operacyjnego i ryzyka technologicznego.

2. Zakres stosowania

Procedurę stosuje się do każdego incydentu, który wpływa na systemy informatyczne, procesy, dane, lokale lub pracowników Banku. Dotyczy to także incydentów powstałych po stronie dostawców usług zewnętrznych, jeżeli wywołują one skutki w działalności Banku.

Procedura obejmuje incydenty następujących rodzajów:

- 1) incydenty bezpieczeństwa informacji, w szczególności:
 - a) nieuprawniony dostęp do systemów, danych lub rachunków Klientów;
 - b) złośliwe oprogramowanie, w tym oprogramowanie szkodzące dane w celu wymuszenia okupu;
 - c) ataki typu odmowa usługi na kanały elektroniczne Banku;
 - d) wyłudzenie danych uwierzytelniających Klientów lub pracowników (phishing, vishing, smishing);
- 2) incydenty operacyjne, w szczególności:
 - a) awarie systemów centralnych, w tym systemu centralnego CBS-PRZYKŁAD, oraz systemów rozliczeniowych;
 - b) niedostępność bankowości elektronicznej, bankomatów lub terminali płatniczych;
 - c) błędy w przetwarzaniu transakcji prowadzące do nieprawidłowych obciążeń lub uznań rachunków;
 - d) niedostępność kluczowych dostawców lub podwykonawców;
- 3) incydenty związane z bezpieczeństwem fizycznym, jeżeli mogą skutkować utratą informacji lub środków Klientów;
- 4) naruszenia ochrony danych osobowych.

Procedura obowiązuje wszystkich pracowników Banku, osoby świadczące pracę na podstawie umów cywilnoprawnych oraz pracowników podmiotów zewnętrznych, którzy mają dostęp do systemów lub danych Banku. Obowiązek zgłoszenia incydentu dotyczy każdej z tych osób, niezależnie od zajmowanego stanowiska.

Procedury nie stosuje się do rutynowych zgłoszeń serwisowych niewpływających na bezpieczeństwo lub ciągłość działania, które obsługuje się w trybie wsparcia użytkowników. Reklamacje Klientów rozpatruje się według odrębnych zasad; jeżeli reklamacja ujawnia incydent, pracownik postępuje zgodnie z niniejszą procedurą.

3. Podstawy prawne i dokumenty powiązane

Procedurę opracowano na podstawie przepisów powszechnie obowiązujących oraz regulacji wewnętrznych Banku.

1. Z przepisów powszechnie obowiązujących szczególne znaczenie mają:
 - 1) obowiązki dostawców usług płatniczych w zakresie bezpieczeństwa i zgłaszania

poważnych incydentów określa ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30);

- 2) wymogi dotyczące zarządzania ryzykiem, kontroli wewnętrznej i ciągłości działania banków wynikają z przepisów prawa bankowego — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646);
 - 3) zasady postępowania w razie naruszenia ochrony danych osobowych określa ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781) oraz rozporządzenie Parlamentu Europejskiego i Rady (UE) 2016/679.
2. Dokumenty wewnętrzne, z którymi procedura jest powiązana, to:
- 1) polityka bezpieczeństwa informacji Banku;
 - 2) plan ciągłości działania oraz plany awaryjnego odtwarzania systemów;
 - 3) instrukcja zarządzania uprawnieniami i dostępem do systemów;
 - 4) procedura obsługi reklamacji Klientów;
 - 5) procedura obsługi wniosków osób, których dane dotyczą.

W razie rozbieżności między procedurą a przepisami powszechnie obowiązującymi lub wytycznymi organu nadzoru stosuje się te przepisy lub wytyczne, a właściciel procedury niezwłocznie wszczyna tryb jej zmiany.

4. Odpowiedzialności

Za obsługę incydentów w Banku odpowiadają jednostki i osoby wymienione poniżej. Zakres ich zadań dotyczy każdej fazy obsługi incydentu: od wykrycia po przegląd końcowy. Zadania pozostałych jednostek opisano w dalszych częściach procedury.

1. **Pracownik** każdej jednostki Banku:
 - 1) zgłasza każde zauważone zdarzenie wskazujące na incydent w terminie 30 minut od jego zauważenia;
 - 2) nie podejmuje na własną rękę działań naprawczych, które mogłyby zniekształcić ślady incydentu;
 - 3) stosuje się do poleceń Zespołu wydanych w trakcie obsługi incydentu.
2. **Kierownik jednostki organizacyjnej:**
 - 1) zapewnia znajomość procedury wśród podległych pracowników, w tym przeszkolenie nowych pracowników w terminie 30 dni od zatrudnienia;
 - 2) wyznacza osobę kontaktową do spraw incydentów w swojej jednostce;
 - 3) udostępnia pracowników i zasoby potrzebne do obsługi incydentu.
3. **Departament Bezpieczeństwa**, jako właściciel procedury:
 - 1) prowadzi Rejestr i nadzoruje jego kompletność;
 - 2) kieruje pracami Zespołu i wyznacza kierownika incydentu;
 - 3) dokonuje klasyfikacji incydentów i zatwierdza zmianę ich poziomu ważności;
 - 4) przygotowuje zawiadomienia dla organu nadzoru i koordynuje współpracę z zespołem CSIRT;
 - 5) odpowiada za aktualność procedury, testy i ćwiczenia.

4. **Departament Informatyki** odpowiada za techniczną obsługę incydu: izolowanie systemów, analizę techniczną, usunięcie przyczyn i przywrócenie działania usług, a także za zabezpieczanie logów i obrazów systemów.
5. **Departament Zgodności** ocenia, czy incydent wymaga zawiadomienia organu nadzoru, opiniuje treść zawiadomień i monitoruje realizację zaleceń po incydencie.
6. **Inspektor Ochrony Danych** ocenia, czy incydent stanowi naruszenie ochrony danych osobowych, określa ryzyko dla osób, których dane dotyczą, oraz opracowuje zgłoszenie do organu ochrony danych i powiadomienia osób zainteresowanych.
1. **Radca prawny** wspiera Zespół w zakresie oceny skutków prawnych incydu i obowiązków informacyjnych Banku. Radca prawny:
 - 1) ocenia, czy zdarzenie wypełnia przesłanki naruszenia ochrony danych osobowych lub incydu podlegającego zgłoszeniu organowi nadzoru;
 - 2) opiniuje treść zawiadomień kierowanych do organów, klientów i kontrahentów;
 - 3) wskazuje sposób zabezpieczenia dowodów, aby mogły zostać wykorzystane w postępowaniu cywilnym lub karnym;
 - 4) ocenia roszczenia klientów wynikające z incydu i przygotowuje stanowisko Banku.
2. Opinie radcy prawnego wydane w trakcie incydu są dołączane do karty incydu jako odrębne załączniki.
1. **Kierownicy jednostek organizacyjnych** odpowiadają za znajomość niniejszej procedury przez podległych pracowników. Kierownik jednostki:
 - 1) zapewnia, aby każdy nowy pracownik został przeszkolony w zakresie zgłaszania incydentów w wymaganym terminie;
 - 2) niezwłocznie przekazuje Dyżurnemu informacje o zdarzeniach zauważonych w jednostce, także gdy nie zostały zgłoszone przez pracownika;
 - 3) wyznacza zastępstwo osób kluczowych dla obsługi incydentów na czas urlopów i nieobecności;
 - 4) oddelegowuje na prośbę Kierownika incydu pracowników posiadających wiedzę o procesach objętych zdarzeniem.
2. Kierownik jednostki, w której wystąpił incydent, uczestniczy w przeglądzie po incydencie i odpowiada za terminową realizację zaleceń dotyczących jego jednostki.
1. **Inspektor ochrony danych** jest informowany o każdym incydencie, który może dotyczyć danych osobowych, nie później niż w terminie 2 godzin od zaklasyfikowania incydu. Inspektor:
 - 1) ocenia ryzyko naruszenia praw i wolności osób, których dane dotyczą, niezależnie od oceny dokonanej przez Zespół;
 - 2) przedstawia stanowisko co do konieczności zgłoszenia naruszenia organowi nadzoru i zawiadomienia osób, których dane dotyczą;
 - 3) prowadzi rejestr naruszeń ochrony danych i dba o jego zgodność z rejestrem incydentów;
 - 4) jest punktem kontaktowym dla organu nadzoru w sprawach naruszeń; dane kontaktowe Inspektora to iod@bank.example.
2. Zespół nie może ograniczać Inspektorowi dostępu do informacji o incydencie ani

wywierać wpływu na wyrażane przez niego stanowisko.

Jednostka prawna (Departament Prawny) udziela wsparcia w zakresie obowiązków prawnych Banku, zabezpieczenia dowodów, zawiadomień o podejrzeniu popełnienia przestępstwa, treści oświadczeń oraz roszczeń związanych z incydemtem. Jednostka prawna ocenia także, czy ujawnienie informacji podmiotom zewnętrznym nie narusza tajemnicy bankowej.

Jednostka operacji (Departament Operacji) ocenia wpływ incydemtu na realizację transakcji i rozliczeń, wstrzymuje lub wznowia przetwarzanie operacji, koryguje błędnie zaksięgowane operacje oraz ustala listę rachunków i Klientów dotkniętych incydemtem.

5. Definicje

Użyte w procedurze określenia oznaczają:

- 1) **Bank** — Bank Przykładowy S.A.;
- 2) **Klient** — osoba, która zamierza korzystać z produktów lub usług Banku;
- 3) **Pracownik** — osoba zatrudniona w Banku, realizująca czynności objęte procedurą;
- 4) **Właściciel procedury** — komórka organizacyjna odpowiedzialna za jej aktualność i stosowanie;
- 5) **Dzień roboczy** — dzień od poniedziałku do piątku, z wyłączeniem dni ustawowo wolnych od pracy;
- 6) **Trwały nośnik** — nośnik umożliwiający zachowanie informacji w sposób dostępny do późniejszego wykorzystania;
- 7) **Placówka** — jednostka Banku obsługująca Klientów;
- 8) **Infolinia** — telefoniczny punkt obsługi Klientów, numer 800 000 001;
- 9) **Eskalacja** — przekazanie sprawy do jednostki lub osoby o wyższych uprawnieniach decyzyjnych.

Na potrzeby procedury przyjmuje się dodatkowo następujące określenia:

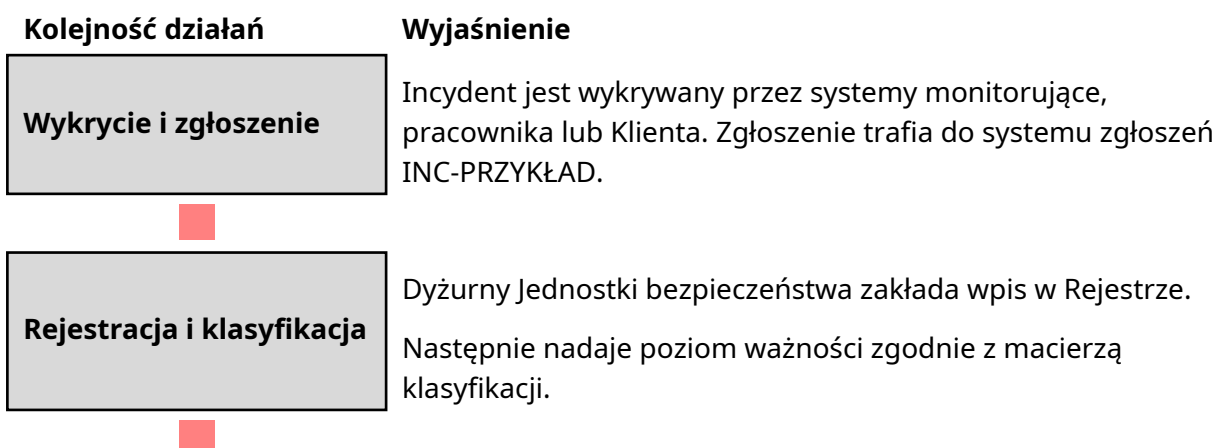
- 1) **Incydent** — zdarzenie, które godzi w poufności, integralności lub dostępności informacji albo ciągłości działania usług, bądź jest uznawane o spowodowanie takiego naruszenia;
- 2) **Incydent bezpieczeństwa** — incydemt związany z nieuprawnionym lub nieprawidłowym działaniem wobec informacji, systemów lub osób;
- 3) **Incydent operacyjny** — incydemt wynikający z awarii, błędu lub zakłócenia procesów, systemów albo dostawców, niebędący działaniem celowym;
- 4) **Incydent poważny** — incydemt o poziomie ważności krytycznym lub wysokim, spełniający kryteria zgłoszenia organowi nadzoru;
- 5) **Organ nadzoru** — organ nadzoru właściwy dla Banku, któremu przekazuje się zawiadomienia o incydemtach poważnych;
- 6) **CSIRT** — zespół CSIRT właściwy dla sektora finansowego, z którym Bank wymienia informacje o zagrożeniach;
- 7) **Naruszenie ochrony danych osobowych** — naruszenie bezpieczeństwa prowadzące do przypadkowego lub bezprawnego zniszczenia, utraty, zmiany, nieuprawnionego

ujawnienia danych osobowych lub dostępu do nich;

- 8) **Kierownik incydu** — osoba wyznaczona przez Jednostkę bezpieczeństwa, która koordynuje obsługę konkretnego incydu;
- 9) **Zespół** — Zespół Reagowania na Incydenty, złożony z przedstawicieli jednostek wskazanych w procedurze i powoływany do obsługi incydentów o poziomie wysokim i krytycznym;
- 10) **Rejestr** — centralny rejestr incydentów o nazwie RINC, prowadzony w systemie zgłoszeń INC-PRZYKŁAD;
- 11) **System SIEM** — system monitorowania zdarzeń SIEM-PRZYKŁAD, który zbiera i koreluje zdarzenia z systemów informatycznych;
- 12) **Pokój operacyjny** — wirtualny pokój operacyjny incydu, w którym prowadzi się dziennik zdarzeń i wymianę ustaleń podczas obsługi incydu;
- 13) **Jednostka bezpieczeństwa** — Departament Bezpieczeństwa; **Jednostka informatyki** — Departament Informatyki; **Jednostka zgodności** — Departament Zgodności; **Jednostka operacji** — Departament Operacji; **Jednostka prawna** — Departament Prawny;
- 14) **Jednostka komunikacji** — Biuro Komunikacji Korporacyjnej; **Jednostka obsługi klienta** — Departament Obsługi Klienta; **Jednostka ciągłości** — Biuro Ciągłości Działania; **Jednostka ryzyka** — Departament Ryzyka; **Jednostka audytu** — Departament Audytu Wewnętrznego; **Jednostka kadr** — Departament Zasobów Ludzkich;
- 15) **Inspektor** — Inspektor Ochrony Danych; **Zarząd** — Zarząd Banku;
- 16) **Ograniczenie skutków** — działania zatrzymujące rozprzestrzenianie się incydu bez usuwania jego przyczyny;
- 17) **Materiał dowodowy** — logi, obrazy dysków, zapisy rozmów, wiadomości i inne dane, które mogą służyć ustaleniu przebiegu incydu;
- 18) **RTO i RPO** — odpowiednio maksymalny akceptowalny czas przywrócenia usługi oraz maksymalna akceptowalna utrata danych, określone w planie ciągłości działania.

6. Opis postępowania — wykrywanie i rejestracja incydu

Poniższy schemat przedstawia podstawowy przebieg obsługi incydu. Szczegółowe zasady dla poszczególnych etapów opisano w dalszej części procedury.



Kolejność działań	Wyjaśnienie
Ograniczenie skutków	Zespół zatrzymuje rozprzestrzenianie się incyduentu i zabezpiecza ślady.
Komunikacja i raportowanie	Informowani są Klienci, kierownictwo, organ nadzoru oraz inne uprawnione podmioty w terminach określonych procedurą.
Usunięcie i przywrócenie	Usuwa się przyczynę incyduentu i przywraca działanie usług według priorytetów ciągłości działania.
Przegląd i wnioski	Po zamknięciu incyduentu przeprowadza się przegląd, a zalecenia wprowadza do planu działań.

6.1. Źródła wykrywania. Incydenty identyfikuje się na podstawie następujących źródeł:

- 6.1.1. alertów systemu SIEM (SIEM-PRZYKŁAD), który koreluje zdarzenia z systemów informatycznych, zapór sieciowych, systemów antywirusowych i systemów kontroli dostępu;
- 6.1.2. zgłoszeń pracowników przekazywanych przez system zgłoszeń INC-PRZYKŁAD, telefonicznie pod numerem dyżurnym 800 000 040 lub pocztą elektroniczną na adres incydenty@bank.example;
- 6.1.3. zgłoszeń Klientów przyjmowanych na infolinii 800 000 001, w placówkach i w reklamacjach;
- 6.1.4. komunikatów dostawców zewnętrznych, partnerów rozliczeniowych, zespołu CSIRT oraz organu nadzoru;
- 6.1.5. wyników kontroli, audytów, testów penetracyjnych i monitoringu transakcji pod kątem nadużyć.

6.2. Zgłoszenie przez pracownika. Pracownik, który zauważy zdarzenie mogące być incyduentem, zgłasza je w terminie 30 minut od jego zauważenia.

- 6.2.1. Zgłoszenie obejmuje opis zdarzenia, czas jego zauważenia, nazwę systemu lub procesu, liczbę i rodzaj podejrzanych operacji oraz dane osoby zgłaszającej; wzór zgłoszenia stanowi formularz F-BEZ-01.
- 6.2.2. Jeżeli zdarzenie może mieć skutki krytyczne (np. niedostępność systemu centralnego, wyciek danych, podejrzenie przejęcia kont uprzywilejowanych), pracownik najpierw dzwoni na numer dyżurny, a dopiero potem uzupełnia formularz.
- 6.2.3. Pracownik zachowuje wiadomość, plik lub zrzut ekranu, które wzbudziły podejrzenie, i nie przekazuje ich dalej poza kanały służbowe.

6.3. Przyjęcie zgłoszenia. Dyżurny Jednostki bezpieczeństwa przyjmuje zgłoszenie w systemie zgłoszeń, niezwłocznie potwierdza jego przyjęcie osobie zgłaszającej i weryfikuje kompletność zgłoszenia.

- 6.3.1. Gdy zgłoszenie jest niekompletne, dyżurny uzupełnia je w rozmowie z osobą zgłaszającą, nie wstrzymując rejestracji.
 - 6.3.2. Zgłoszenia wielokrotne dotyczące tego samego zdarzenia łączy się w jeden wpis, zachowując ich historię.
 - 6.4. Rejestracja incydentu. Dyżurny zakłada wpis w Rejestrze i przypisuje mu unikalny numer. Do wpisu wprowadza się co najmniej:
 - 6.4.1. datę i godzinę wykrycia oraz zgłoszenia, a także źródło informacji;
 - 6.4.2. opis zdarzenia i systemy lub procesy, których dotyczy;
 - 6.4.3. wstępną ocenę skutków, w tym liczbę Klientów i wartość operacji objętych incydem;
 - 6.4.4. imię i nazwisko osoby odpowiedzialnej za dalszą obsługę oraz kartę incydentu według formularza F-BEZ-02.
 - 6.5. Wstępna weryfikacja. Dyżurny sprawdza w ciągu kilkunastu minut, czy zdarzenie rzeczywiście jest incydem, a nie fałszywym alarmem. Fałszywy alarm zamyka się z adnotacją o przyczynie; wpis pozostaje w Rejestrze.
 - 6.6. Powiadomienie dyżurnych. Przy zdarzeniach, które mogą mieć poziom wysoki lub krytyczny, dyżurny niezwłocznie powiadamia kierownika Jednostki bezpieczeństwa i dyżurnego Jednostki informatyki.
 - 6.7. Dyżury i dostępność. Jednostka bezpieczeństwa i Jednostka informatyki zapewniają dyżury w trybie całodobowym. Harmonogram dyżurów jest dostępny w systemie zgłoszeń i przekazywany dyżurnym telefonicznie na początku każdego miesiąca.
 - 6.8. Zasady dyżuru poza godzinami pracy. Dyżurny poza godzinami pracy:
 - 6.8.1. jest osiągalny pod numerem służbowym i podejmuje zgłoszenie w czasie pierwszej reakcji właściwym dla poziomu ważności;
 - 6.8.2. ma zdalny dostęp do Rejestru i systemu SIEM oraz aktualną listę kontaktów alarmowych;
 - 6.8.3. w przypadku niemożności objęcia dyżuru bez zbędnej zwłoki powiadamia kierownika Jednostki bezpieczeństwa, który wyznacza zastępstwo.
 - 6.9. Lista kontaktów alarmowych. Lista kontaktów alarmowych obejmuje numery służbowe członków Zespołu, dyrektorów jednostek, kluczowych dostawców, zespołu CSIRT i organu nadzoru. Lista jest przechowywana również w postaci papierowej w zabezpieczonym miejscu, tak aby była dostępna w razie niedostępności systemów.
- Nie każde zgłoszenie okazuje się incydem. Zgłoszenia, które po analizie nie spełniają definicji incydentu, zamyka się z odpowiednim uzasadnieniem, ale nie usuwa się ich z rejestru, ponieważ stanowią źródło wiedzy o typowych błędach i zagrożeniach.
- 6.10. Kategorie zamknięcia bez incydentu.
 - 6.10.1. zdarzenie normalne: działanie systemu zgodne z założeniami, choć niezrozumiałe dla zgłaszającego;
 - 6.10.2. błąd użytkownika bez skutków dla bezpieczeństwa lub działalności Banku;
 - 6.10.3. alarm fałszywy wygenerowany przez system monitorowania;
 - 6.10.4. zdarzenie zgłoszone podwójnie, które połączono z istniejącym zgłoszeniem.

- 6.11. Informacja zwrotna. Dyżurny informuje zgłaszającego o wyniku analizy i dziękuje mu za zgłoszenie, a w razie potrzeby wyjaśnia, dlaczego zdarzenie nie jest incydem.
- 6.12. Wykorzystanie wniosków. Jednostka bezpieczeństwa raz na kwartał analizuje zgłoszenia zamknięte bez incydemu i, jeżeli zawierają one powtarzające się błędy, przekazuje wnioski do szkolenia pracowników.

Zgłoszenia wpływające poza godzinami pracy placówek i jednostek obsługuje się w takim samym trybie jak w dni robocze. Gotowość zapewnia całodobowy dyżur, a w sytuacjach o klasyfikacji wysokiej i krytycznej — dyżur rezerwowy.

- 6.13. Przyjęcie zgłoszenia w nocy i w dni wolne. Dyżurny przyjmuje zgłoszenie pod numerem 800 000 040 lub z adresu incydenty@bank.example i rejestruje je zgodnie z ogólnymi zasadami.
- 6.14. Wstępne ograniczenie skutków. Jeżeli zwłoka mogłaby spowodować istotną szkodę, Dyżurny podejmuje decyzję o niezbędnych działaniach tymczasowych.
 - 6.14.1. Do działań tymczasowych należą: odłączenie urządzenia od sieci, zablokowanie konta, zawieszenie zlecenia płatniczego lub czasowe wyłączenie kanału elektronicznego.
 - 6.14.2. Dyżurny nie podejmuje działań nieodwracalnych, takich jak usunięcie danych lub reinstalacja systemu, bez zgody Kierownika incydemu.
- 6.15. Wezwanie osób. Dyżurny wzywa Kierownika incydemu i niezbędnych członków Zespołu, korzystając z listy kontaktów alarmowych, a brak potwierdzenia odbioru wezwania w ciągu kwadransu skutkuje wezwaniem zastępcy.
- 6.16. Przekazanie sprawy. Rano następnego dnia roboczego Dyżurny przekazuje Kierownikowi incydemu pisemne podsumowanie działań podjętych w nocy, które włącza się do dziennika zdarzeń.

Informacje o zdarzeniach mogą pochodzić także spoza Banku. Źródłami zewnętrznymi są w szczególności zespół zespół CSIRT właściwy dla sektora finansowego, dostawcy usług, inne instytucje finansowe, organy ścigania oraz osoby postronne, w tym klienci i dziennikarze.

- 6.17. Przyjęcie informacji z zewnątrz. Informację o zdarzeniu otrzymaną od podmiotu zewnętrznego przyjmuje każdy pracownik, który ją otrzymał, i niezwłocznie przekazuje Dyżurnemu.
 - 6.17.1. Pracownik nie potwierdza ani nie zaprzecza zasadności informacji, jeżeli nie jest do tego upoważniony; ogranicza się do podania, że sprawa zostanie przekazana właściwej jednostce.
 - 6.17.2. Pracownik zapisuje dane kontaktowe nadawcy, dokładną treść informacji oraz czas jej otrzymania.
- 6.18. Weryfikacja wiarygodności. Dyżurny sprawdza wiarygodność informacji, porównując ją z danymi z systemu monitorowania i rejestrem incydentów.
 - 6.18.1. Jeżeli informacja pochodzi od nieznanego nadawcy, Dyżurny ustala możliwość jej weryfikacji niezależnym kanałem, na przykład przez oddzwonienie na numer z oficjalnej strony podmiotu.
 - 6.18.2. Informacji o podatnościach i zagrożeniach otrzymanych od zespołu zespół CSIRT

właściwy dla sektora finansowego nie ignoruje się nawet wtedy, gdy Bank nie odnotował żadnych niepokojących zdarzeń.

- 6.19. Wpis do rejestru. Informację przyjętą jako wiarygodną rejestruje się w systemie INC-PRZYKŁAD, a w polu źródło zgłoszenia wpisuje się jej pochodzenie zewnętrzne.

7. Opis postępowania — klasyfikacja i ocena incydu

Klasyfikacja incydu służy ustaleniu wymaganego czasu reakcji, składu zespołu obsługującego incydent i zakresu zawiadomień. Poziom ważności określa się na podstawie najpoważniejszego ze skutków wskazanych w tabeli. Pełną macierz klasyfikacji zawiera Załącznik nr 1.

Poziom ważności	Kryteria (wystarczy spełnienie jednego)	Pierwsza reakcja — do
Krytyczny	incydent dotyczy ponad 1 000 Klientów, albo niedostępność kluczowej usługi trwa dłużej niż 2 godziny, albo potencjalna strata przekracza 500 000,00 zł, albo doszło do naruszenia danych o wysokim ryzyku	15 minut
Wysoki	incydent dotyczy od 100 do 1 000 Klientów, albo niedostępność usługi trwa od 30 minut do 2 godzin, albo potencjalna strata przekracza 50 000,00 zł	1 godziny
Średni	ograniczone zakłócenie jednego procesu lub kanału, bez wpływu na rozliczenia, z istniejącym obejściem	4 godzin
Niski	zdarzenie bez wpływu na Klientów i procesy, zablokowane w całości przez zabezpieczenia	2 dni roboczych

- 7.1. Ocena wstępna. Dyżurny Jednostki bezpieczeństwa dokonuje wstępnej klasyfikacji w ciągu 2 godzin od zarejestrowania zgłoszenia.

7.1.1. Klasyfikacja obejmuje ocenę wpływu na poufność, integralność i dostępność informacji, liczbę dotkniętych Klientów, wartość operacji i ryzyko dla reputacji Banku.

7.1.2. Gdy dane są niepełne, przyjmuje się poziom wyższy; obniżenie poziomu jest możliwe dopiero po uzyskaniu pełnych danych.

- 7.2. Ustalenie rodzaju incydu. Dyżurny przypisuje incydent do kategorii: złośliwe oprogramowanie, nieuprawniony dostęp, odmowa usługi, wyłudzenie danych, wyciek danych, awaria systemu, błąd przetwarzania, incydent dostawcy lub incydent fizyczny. Kategoria wpływa na doborze członków Zespołu.

- 7.3. Ocena obowiązków zewnętrznych. Jednostka zgodności oraz Inspektor oceniają, czy incydent:

7.3.1. spełnia kryteria incydu poważnego i wymaga zawiadomienia organu nadzoru;

7.3.2. stanowi naruszenie ochrony danych osobowych wymagające zgłoszenia do organu ochrony danych lub powiadomienia osób, których dane dotyczą;

7.3.3. wymaga zawiadomienia organów ścigania lub innych uprawnionych instytucji.

- 7.4. Powołanie Zespołu. Incydent o poziomie wysokim lub krytycznym obsługuje Zespół, którego kierownikiem jest wyznaczony przedstawiciel Jednostki bezpieczeństwa. Dla

incydentów średnich i niskich obsługę prowadzi dyżurny wraz z właściwą jednostką.

- 7.5. Zmiana poziomu ważności. Poziom ważności może zostać zmieniony w trakcie obsługi, jeżeli pojawią się nowe informacje. Zmianę wraz z uzasadnieniem i godziną odnotowuje się w Rejestrze; podwyższenie poziomu uruchamia obowiązki właściwe dla nowego poziomu od chwili zmiany.
- 7.6. Eskalacja. Incydent krytyczny kierownik Jednostki bezpieczeństwa niezwłocznie zgłasza członkowi Zarządu nadzorującemu ryzyko; incydent wysoki — dyrektorom departamentów dotkniętych incydem.

Poza poziomem klasyfikacji każdemu incydentowi przypisuje się rodzaj, który determinuje właściwy zespół specjalistów i sposób dalszego postępowania. Rodzaj wpisuje się w rejestrze RINC.

- 7.7. Incydent cyberbezpieczeństwa: złośliwe oprogramowanie, nieuprawniony dostęp, atak na dostępność usług, przejęcie konta, wyłudzenie danych.

7.7.1. Obsługę prowadzi Jednostka bezpieczeństwa z udziałem Jednostki informatyki.

- 7.8. Incydent operacyjny: awaria systemu, błąd w przetwarzaniu transakcji, utrata danych w wyniku błędu ludzkiego, awaria dostawcy.

7.8.1. Obsługę prowadzi właściciel procesu przy wsparciu Jednostki ciągłości działania.

- 7.9. Incydent dotyczący danych osobowych: nieuprawnione ujawnienie, utrata lub zmiana danych, wysłanie dokumentów do niewłaściwego adresata.

7.9.1. Obsługę prowadzi Kierownik incydemu wspólnie z Inspektorem ochrony danych.

- 7.10. Incydent fizyczny: kradzież lub zniszczenie sprzętu, włamanie do pomieszczeń, nieuprawniony dostęp osób postronnych do stref chronionych.

7.10.1. Obsługę prowadzi pracownik ochrony we współpracy z Jednostką bezpieczeństwa; zdarzenie zgłasza się także Policji.

- 7.11. Incydent z udziałem pracownika: podejrzenie nadużycia, ujawnienia informacji poufnych lub działania na szkodę Banku.

7.11.1. Obsługę prowadzi Jednostka bezpieczeństwa z Jednostką kadr, a dostęp do informacji o sprawie ogranicza się do niezbędnego minimum.

Incydent może należeć do kilku rodzajów jednocześnie; wówczas w karcie incydemu wskazuje się rodzaj wiodący i rodzaje dodatkowe.

- 7.12. Incydenty powiązane. Gdy kilka zgłoszeń ma tę samą przyczynę, rejestruje się jeden incydent nadrzędny, a pozostałe zgłoszenia łączy się z nim jako zdarzenia podrzędne. Poziom ważności ustala się dla całości.

- 7.13. Incydenty jednoczesne. Jeżeli w tym samym czasie występuje kilka niepowiązanych incydentów, kierownik Jednostki bezpieczeństwa ustala kolejność ich obsługi i wyznacza odrębnych kierowników incydentów; Zespół może być w takim przypadku podzielony na grupy.

- 7.14. Incydent nawracający. Incydent, który powtarza się z tą samą przyczyną w ciągu ostatnich sześciu miesięcy, klasyfikuje się co najmniej o jeden poziom wyżej niż poprzednie wystąpienie, a przegląd po incydencie jest obowiązkowy niezależnie od poziomu.

- 7.15. Szacowanie skutków finansowych. Przy klasyfikacji określa się potencjalną stratę finansową, obejmującą:
- 7.15.1. bezpośrednie straty Klientów i Banku wynikające z nieautoryzowanych lub błędnych operacji;
 - 7.15.2. koszty usunięcia skutków incydentu, w tym pracę zespołów i usługi zewnętrzne;
 - 7.15.3. przewidywane odszkodowania, kary lub rekompensaty dla Klientów;
 - 7.15.4. utracone przychody z tytułu niedostępności usług.
- 7.16. Szacunek wstępny. Szacunek wstępny jest oceną ostrożnościową — przyjmuje się wartość górnej granicy rozsądnego przedziału. Jednostka ryzyka weryfikuje szacunek po zamknięciu incydentu i przekazuje wartość rzeczywistą do Rejestru.
- 7.17. Skutki niefinansowe. Obok skutków finansowych ocenia się wpływ na zaufanie Klientów, relacje z organem nadzoru, możliwość wykonywania zobowiązań wobec partnerów rozliczeniowych oraz bezpieczeństwo pracowników.

Dla incydentów o klasyfikacji wysokiej i krytycznej, w ciągu 2 godzin od klasyfikacji wstępnej, Zespół sporządza ocenę wpływu incydentu na działalność Banku. Ocenę przygotowuje się na podstawie następujących kroków.

- 7.18. Identyfikacja procesów dotkniętych incydentem.
- 7.18.1. Wskazuje się procesy i usługi, które nie działają lub działają w ograniczonym zakresie, wraz z określeniem właścicieli tych procesów.
 - 7.18.2. Ustala się, czy incydent dotyczy procesów wspierających, czy też bezpośrednio obsługi klientów.
- 7.19. Oszacowanie skutków dla klientów.
- 7.19.1. Szacuje się liczbę klientów, którzy nie mogą skorzystać z usług, oraz liczbę klientów, których dane lub środki mogły zostać narażone.
 - 7.19.2. Określa się, czy klienci mogą skorzystać z kanałów zastępczych, takich jak placówki, infolinia lub bankomaty.
- 7.20. Oszacowanie skutków finansowych i prawnych. Zespół, wspólnie z Jednostką ryzyka i radcą prawnym, szacuje przewidywane straty, koszty usunięcia skutków oraz ryzyko roszczeń i kar.
- 7.21. Wskazanie działań priorytetowych. Ocenę kończy lista działań uporządkowana według pilności; Kierownik incydentu przedstawia ją kierownictwu w ramach pierwszej informacji o incydencie.

8. Opis postępowania — reagowanie i ograniczanie skutków

- 8.1. Uruchomienie Zespołu. Kierownik incydentu zwołuje Zespół w czasie pierwszej reakcji właściwym dla poziomu ważności i otwiera pokój operacyjny, w którym prowadzi się chronologiczny zapis ustaleń i decyzji.
- 8.1.1. Każdy członek Zespołu potwierdza gotowość i podaje zakres swoich działań.
 - 8.1.2. Kierownik incydentu przydziela zadania i wyznacza osobę prowadzącą dziennik zdarzeń.
- 8.2. Ocena zakresu. Jednostka informatyki ustala, które systemy, dane i konta są dotknięte

incydentem, od kiedy i w jaki sposób do niego doszło, oraz czy incydent trwa.

8.3. Ograniczenie skutków. Zespół podejmuje działania zatrzymujące rozprzestrzenianie się incydentu, dobierając je do rodzaju zdarzenia:

- 8.3.1. odłączenie zainfekowanych stacji i segmentów od sieci Banku bez wyłączania zasilania (aby zachować zawartość pamięci);
- 8.3.2. zablokowanie lub zmiana danych uwierzytelniających przejętych kont, tokenów i certyfikatów;
- 8.3.3. zablokowanie złośliwych adresów, domen i nadawców wiadomości na urządzeniach brzegowych;
- 8.3.4. czasowe wyłączenie podatnej funkcji lub kanału, jeżeli jest to proporcjonalne do ryzyka;
- 8.3.5. wstrzymanie wypłat lub zleceń płatniczych objętych podejrzeniem nadużycia, w uzgodnieniu z Jednostką operacji.

8.4. Decyzje o wyłączeniu usług. Decyzję o wyłączeniu kanału lub usługi dla Klientów podejmuje kierownik incydentu w porozumieniu z dyrektorem Jednostki operacji; w przypadku incydentu krytycznego powiadamia się o niej członka Zarządu. Wyłączenie ma trwać jak najkrócej, a jego przyczyny, czas i zakres odnotowuje się w dzienniku zdarzeń.

8.5. Zabezpieczenie dowodów przed naprawą. Zanim wykona się czynności zmieniające stan systemów (restart, reinstalacja, czyszczenie), zabezpiecza się materiał dowodowy zgodnie z zasadami opisanymi w dalszej części procedury.

8.6. Usunięcie przyczyny. Po ograniczeniu skutków Zespół usuwa przyczynę incydentu:

- 8.6.1. usuwa złośliwe oprogramowanie i wszelkie mechanizmy trwałej obecności atakującego;
- 8.6.2. instaluje poprawki i zmienia konfiguracje, które umożliwiły incydent;
- 8.6.3. sprawdza, czy w innych systemach nie występują te same słabości;
- 8.6.4. dokumentuje wykonane czynności w karcie incydentu.

8.7. Raport stanu. Kierownik incydentu przygotowuje cykliczny raport stanu: dla incydentu krytycznego co godzinę, dla wysokiego — co cztery godziny. Raport obejmuje status, podjęte działania, planowane czynności i szacowany czas przywrócenia usług.

8.8. Współpraca z wyspecjalizowanymi podmiotami. Gdy Bank nie dysponuje wystarczającymi zasobami do analizy lub usunięcia skutków incydentu, kierownik incydentu może za zgodą dyrektora Jednostki bezpieczeństwa skorzystać ze wsparcia zewnętrznego zespołu specjalistów, z którym Bank ma zawartą umowę ramową.

- 8.8.1. Umowa z zewnętrznym zespołem obejmuje klauzule poufności i zapewnia, że zespół działa pod nadzorem Banku.
- 8.8.2. Dostęp zespołu do systemów i danych ogranicza się do niezbędnego zakresu i rejestruje.
- 8.8.3. Wyniki analizy zespół przekazuje jedynie Bankowi.

W przypadku wykrycia złośliwego oprogramowania, w tym oprogramowania szyfrującego dane, obowiązują poniższe zasady postępowania, uzupełniające ogólne kroki reagowania.

- 8.9. Ustalenie zakresu zakażenia. Analityk bezpieczeństwa ustala zakażone urządzenia na podstawie wskaźników kompromitacji, takich jak skróty plików, adresy serwerów sterujących i nazwy procesów.
 - 8.9.1. Wskaźniki wprowadza się do systemu SIEM-PRZYKŁAD, który przeszukuje dzienniki z ostatnich trzydziestu dni.
 - 8.9.2. Wyniki przeszukiwania zapisuje się w pokoju operacyjnym incydentu i na bieżąco uzupełnia.
- 8.10. Zablokowanie komunikacji. Adresy i domeny wykorzystywane przez złośliwe oprogramowanie blokuje się na zaporach i w bramach pocztowych.
- 8.11. Usunięcie oprogramowania. Złośliwe oprogramowanie usuwa się wyłącznie po zabezpieczeniu obrazu dysku lub pamięci; w razie wątpliwości co do skuteczności czyszczenia urządzenie instaluje się od nowa z zaufanego nośnika.
- 8.12. Żądanie okupu. Bank nie podejmuje rozmów z autorami żądania okupu ani nie dokonuje płatności bez decyzji Zarządu, podjętej po konsultacji z radcą prawnym i organami ścigania.
- 8.13. Kopie zapasowe. Przed rozpoczęciem odtwarzania danych z kopii zapasowych sprawdza się, że kopie nie zostały zainfekowane, a najpierw odtwarza się dane do odizolowanego środowiska testowego.
- 8.14. Tryb awaryjny. Jeżeli przywrócenie usługi w czasie wynikającym z RTO nie jest możliwe, kierownik incydentu wraz z Jednostką ciągłości wnioskuje do członka Zarządu o uruchomienie planu ciągłości działania.
 - 8.14.1. Plan ciągłości działania uruchamia się decyzją członka Zarządu nadzorującego operacje lub osoby przez niego upoważnionej; decyzję odnotowuje się w dzienniku zdarzeń.
 - 8.14.2. W trybie awaryjnym placówki obsługują Klientów według uproszczonych zasad i w ograniczonym zakresie czynności, zgodnie z planem.
 - 8.14.3. Operacje wykonane w trybie awaryjnym oznacza się i po przywróceniu systemów rekonsyliuje z danymi systemu centralnego CBS-PRZYKŁAD.
- 8.15. Izolacja systemów i sieci. Izolację zainfekowanych lub przejętych systemów przeprowadza Jednostka informatyki na polecenie kierownika incydentu. Przed izolacją ocenia się, czy odłączenie nie spowoduje większej szkody niż pozostawienie systemu w sieci.
 - 8.15.1. Dla systemów krytycznych decyzję o izolacji podejmuje kierownik incydentu w porozumieniu z właścicielem systemu.
 - 8.15.2. Systemy odłączone oznacza się w Rejestrze i w dzienniku zdarzeń, ze wskazaniem godziny odłączenia i osoby, która tego dokonała.
 - 8.15.3. Aby ponownie podłączyć system, wymagana jest zgoda kierownika incydentu.
- 8.16. Segmentacja. Zespół stosuje istniejący podział sieci na segmenty, aby ograniczyć rozprzestrzenianie się incydentu; w razie potrzeby czasowo zamyka połączenia między segmentami.

9. Opis postępowania — komunikacja i raportowanie

Komunikację w trakcie incydentu prowadzi się jedynie według zasad poniżej. Pracownicy nieupoważnieni do kontaktu z mediami, Klientami lub instytucjami zewnętrznymi nie udzielają informacji o incydencie i kierują wszelkie pytania do Jednostki komunikacji.

- 9.1. Komunikacja wewnętrzna. Kierownik incydentu informuje o incydencie osoby i jednostki, które muszą podjąć działania, w zakresie koniecznym do ich wykonania.
 - 9.1.1. Informacje o incydentach krytycznych i wysokich przekazuje się w pokoju operacyjnym, a gdy ten jest niedostępny — telefonicznie.
 - 9.1.2. Pracownikom placówek i infolinii przekazuje się krótką instrukcję: co wiadomo, co mówić Klientom i dokąd kierować pytania.
 - 9.1.3. Informacje o przyczynach i sprawcach incydentu nie są przekazywane pracownikom spoza Zespołu do czasu zakończenia analizy.
- 9.2. Komunikacja z Klientami. Jeżeli incydent dotyczy Klientów, Jednostka komunikacji przygotowuje komunikat, który:
 - 9.2.1. w prosty sposób informuje, czego incydent dotyczy i jakich usług lub produktów;
 - 9.2.2. wskazuje zalecane działania Klienta (np. zmiana hasła, unikanie wskazanych linków) oraz numer infolinii 800 000 001;
 - 9.2.3. nie zawiera szczegółów technicznych, które mogłyby ułatwić dalsze ataki;
 - 9.2.4. przypomina, że Bank nie prosi o podanie pełnych danych uwierzytelniających.
- 9.3. Termin powiadomienia Klientów. Klientów, których dotyczy incydent o wysokim ryzyku dla ich środków lub danych, powiadamia się w terminie 24 godzin od potwierdzenia, że incydent ich dotyczy. Gdy tożsamość dotkniętych Klientów nie jest jeszcze znana, zamieszcza się komunikat ogólny w bankowości elektronicznej i na stronie <https://bank.example>.

Incydenty poważne oraz naruszenia ochrony danych osobowych podlegają zgłoszeniu w terminach określonych poniżej. Terminy liczy się w godzinach, a nie w dniach roboczych — obejmują one dni ustawowo wolne od pracy, noce i weekendy.

- 9.4. Kwalifikacja incydentu poważnego. Jednostka zgodności wspólnie z Jednostką bezpieczeństwa ustala, czy incydent jest incydemtem poważnym. Przy ocenie uwzględnia się zwłaszcza liczbę dotkniętych Klientów, czas trwania, zasięg, wartość transakcji, wpływ na inne instytucje i skutki dla reputacji Banku. Decyzję odnotowuje się w Rejestrze.
- 9.5. Zawiadomienie wstępne. Zawiadomienie wstępne dla organu nadzoru przekazuje się w ciągu 6 godzin od zaklasyfikowania incydentu jako poważnego, a w każdym razie nie później niż w terminie 24 godzin od momentu, w którym Bank dowiedział się o incydencie.
 - 9.5.1. Zawiadomienie przygotowuje Jednostka bezpieczeństwa na formularzu F-BEZ-06, a opiniuje Jednostka zgodności.
 - 9.5.2. Zawiadomienie zawiera dane Banku, datę i godzinę wykrycia, wstępny opis incydentu, szacowany zasięg i rodzaj dotkniętych usług, informację o podjętych działaniach i dane osoby kontaktowej.

- 9.5.3. Zawiadomienie przekazuje się bezpiecznym kanałem wskazanym przez organ nadzoru; brak pełnych danych nie jest powodem opóźnienia — uzupełnia się je w zawiadomieniach kolejnych.
- 9.6. Zawiadomienie pośrednie. Zawiadomienie pośrednie przekazuje się w terminie 72 godzin od zawiadomienia wstępnego albo niezwłocznie po istotnej zmianie stanu incydentu, jeżeli nastąpi ona wcześniej.
- 9.6.1. Zawiadomienie pośrednie zawiera zaktualizowany opis incydentu, ustaloną przyczynę (jeśli jest znana), liczbę dotkniętych Klientów, wartość operacji, podjęte działania naprawcze i przewidywany czas przywrócenia usług.
- 9.6.2. Kolejne aktualizacje przekazuje się w miarę potrzeb, aż do zakończenia incydentu.
- 9.7. Raport końcowy. Raport końcowy przekazuje się w terminie 1 miesiąca od zawiadomienia pośredniego albo od ustania incydentu, zależnie od tego, które zdarzenie nastąpi później. Raport według formularza F-BEZ-03 obejmuje analizę przyczyny źródłowej, pełne skutki, wykonane i planowane środki zaradcze oraz informacje o ewentualnych kosztach.
- 9.8. Naruszenie ochrony danych osobowych — zgłoszenie. Jeżeli Inspektor stwierdzi, że naruszenie może skutkować ryzykiem naruszenia praw lub wolności osób fizycznych, Bank zgłasza je organowi ochrony danych bez zbędnej zwłoki, w miarę możliwości nie później niż w terminie 72 godzin od stwierdzenia naruszenia. Zgłoszenie dokonane po tym terminie wymaga wyjaśnienia przyczyn opóźnienia.
- 9.8.1. Zgłoszenie obejmuje charakter naruszenia, kategorie i przybliżoną liczbę osób oraz rekordów, dane kontaktowe Inspektora (iod@bank.example), możliwe skutki oraz środki zastosowane lub proponowane.
- 9.8.2. Podstawę prawną zgłoszenia stanowią przepisy o ochronie danych osobowych — zob. ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781).
- 9.9. Naruszenie ochrony danych osobowych — powiadomienie osób. Jeżeli naruszenie może powodować wysokie ryzyko naruszenia praw lub wolności osób, których dane dotyczą, Inspektor wspólnie z Jednostką komunikacji przygotowuje powiadomienie tych osób, napisane prostym językiem, i przekazuje je bez zbędnej zwłoki.
- 9.10. Komunikacja z mediami. Z mediami kontaktuje się wyłącznie Jednostka komunikacji za zgodą Zarządu. Treść oświadczeń zatwierdza Jednostka prawna w zakresie ryzyka prawnego, a kierownik incydentu — w zakresie zgodności z faktami.
- 9.10.1. Oświadczenie publiczne obejmuje tylko potwierdzone informacje i nie przesądza o przyczynach ani sprawcach incydentu.
- 9.10.2. Pracownicy, którzy otrzymają pytanie dziennikarza, nie udzielają odpowiedzi i przekazują kontakt do Jednostki komunikacji.
- 9.10.3. Wypowiedzi w mediach społecznościowych o incydencie w imieniu Banku wygłasza wyłącznie Jednostka komunikacji.
- 9.11. Monitorowanie reakcji. Jednostka komunikacji monitoruje publikacje i wpisy dotyczące incydentu i przekazuje kierownikowi incydentu informacje o nieprawdziwych lub szkodliwych doniesieniach.
- 9.12. Zawiadomienie o przestępstwie. W razie uzasadnionego podejrzenia popełnienia

- przestępstwa Jednostka prawna w porozumieniu z Jednostką bezpieczeństwa składa zawiadomienie do właściwych organów ścigania i uzgadnia z nimi zakres współpracy.
- 9.12.1. Rozmiar informacji przekazywanych organom ścigania musi być zgodny z przepisami o tajemnicy bankowej — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646).
- 9.12.2. Przekazanie materiału dowodowego organom ścigania dokumentuje się protokołem według formularza F-BEZ-04.
- 9.12.3. Pracownik Banku nie informuje osób podejrzewanych o toczących się czynnościach.
- 9.13. Współpraca z zespołem CSIRT. W incydentach o charakterze cyberataku Jednostka bezpieczeństwa może przekazać zespołowi CSIRT informacje o wskaźnikach naruszenia bezpieczeństwa (adresy, skróty plików, domeny) w formie pozbawionej danych Klientów. Przekazywanie takich informacji ułatwia ochronę innych instytucji, a Bank może uzyskać od zespołu wsparcie analityczne.
- 9.14. Inne instytucje. Jeżeli incydent może wpływać na partnerów rozliczeniowych, operatorów systemów płatności lub inne instytucje finansowe, kierownik incydentu w porozumieniu z Jednostką zgodności informuje je w zakresie niezbędnym do ochrony ich systemów.
- 9.15. Instrukcja dla infolinii i placówek. Jednostka obsługi klienta otrzymuje od kierownika incydentu krótką instrukcję, która zawiera:
- 9.15.1. stan faktyczny w zakresie, w jakim można go przekazać Klientom;
 - 9.15.2. zalecenia, których należy udzielić Klientom (np. czasowe zaprzestanie korzystania z danej usługi, zmiana hasła);
 - 9.15.3. informację, jak postępować z Klientami, którzy zgłaszają straty;
 - 9.15.4. dane osoby w Jednostce obsługi klienta, do której kieruje się trudniejsze pytania.
- 9.16. Skrypt rozmowy. Pracownicy infolinii korzystają z zatwierdzonego skryptu rozmowy i nie przekraczają zawarte w nim informacje. Pytania, na które skrypt nie daje odpowiedzi, rejestruje się i przekazuje kierownikowi incydentu.
- Incydenty poważne wymagają zawiadomienia organu nadzoru, czyli organ nadzoru. Zawiadomienia przekazuje się w ustalonych terminach, a ich treść jest weryfikowana pod kątem kompletności i spójności z innymi informacjami przekazywanymi przez Bank.
- 9.17. Ocena obowiązku zawiadomienia. Radca prawny wraz z Jednostką zgodności ocenia, czy incydent spełnia kryteria incydentu poważnego, i zapisuje wynik oceny w karcie incydentu.
- 9.18. Zawiadomienie wstępne. Zawiadomienie wstępne w formularzu F-BEZ-06 przekazuje się w terminie 6 godzin od zaklasyfikowania incydentu jako poważnego.
- 9.18.1. Zawiadomienie wstępne zawiera dane Banku, datę wykrycia, ogólny opis incydentu, wstępną ocenę skutków i informację o podjętych działaniach.
 - 9.18.2. Brak pełnych informacji nie uzasadnia opóźnienia; informacje brakujące zawiadomienie wskazuje i uzupełnia się je w kolejnych etapach.
- 9.19. Zawiadomienie pośrednie. Aktualizację zawiadomienia przekazuje się w terminie 72 godzin od zawiadomienia wstępnego albo wcześniej, jeżeli zmienia się istotnie ocena

skutków.

- 9.20. Zawiadomienie końcowe. Raport końcowy zawierający analizę przyczyn źródłowych i podjęte środki naprawcze przekazuje się w terminie 1 miesiąca od zakończenia czynności związanych z usunięciem skutków incydentu.

10. Opis postępowania — zabezpieczenie dowodów, przywrócenie działania i przegląd

- 10.1. Zasady zabezpieczania materiału dowodowego. Materiał dowodowy zabezpiecza się w sposób, który umożliwia wykazać jego autentyczność i nienaruszalność. Czynności wykonują wyłącznie osoby wyznaczone przez kierownika incydentu.
- 10.1.1. Przed każdą czynnością zmieniającą stan systemu wykonuje się kopię logów, obraz dysku lub zrzut pamięci, a dla każdej kopii oblicza się sumę kontrolną.
- 10.1.2. Oryginały dowodów przechowuje się w oznaczonym, zabezpieczonym miejscu; analizę prowadzi się na kopiach.
- 10.1.3. Każde przekazanie dowodu odnotowuje się w protokole według formularza F-BEZ-04 (łańcuch dowodowy): data, godzina, osoba przekazująca, osoba przyjmująca, cel.
- 10.2. Rodzaje zabezpieczanych danych. Zabezpiecza się zwłaszcza:
- 10.2.1. logi systemowe, aplikacyjne, sieciowe i uwierzytelniania z okresu przynajmniej 13 miesięcy wstecz — o ile taki okres jest dostępny;
- 10.2.2. obrazy dysków i zrzuty pamięci zainfekowanych stacji i serwerów;
- 10.2.3. wiadomości phishingowe wraz z nagłówkami technicznymi;
- 10.2.4. zapisy rozmów telefonicznych i korespondencję z osobami zgłaszającymi;
- 10.2.5. zapisy z monitoringu wizyjnego i rejestry wejść w przypadku incydentów fizycznych.
- 10.3. Wstrzymanie usuwania danych. Na czas obsługi incydentu i do zamknięcia wszystkich związanych z nim postępowań Jednostka informatyki wstrzymuje automatyczne usuwanie logów i kopii objętych incydentem (blokada prawna na wniosek Jednostki prawnej).
- 10.4. Ochrona danych w materiale dowodowym. Materiał dowodowy obejmuje często dane osobowe i tajemnicę bankową. Dostęp do niego mają wyłącznie osoby, które go potrzebują do obsługi incydentu; dostęp rejestruje się, a przekazanie materiału poza Bank wymaga zgody Jednostki prawnej.
- 10.5. Plan przywrócenia. Kierownik incydentu wraz z Jednostką informatyki i Jednostką ciągłości ustala kolejność przywracania usług, opierając się na priorytetach określonych w planie ciągłości działania i wartościach RTO oraz RPO. Priorytet mają usługi umożliwiające Klientom dostęp do środków i realizację płatności.
- 10.6. Przywrócenie z kopii. Przywracanie systemów z kopii zapasowych poprzedza sprawdzenie, że kopie nie zostały zainfekowane. Systemy, które były przejęte, przywraca się z zaufanych, zweryfikowanych źródeł, nigdy przez proste usunięcie śladów.
- 10.6.1. Przed uruchomieniem systemu wykonuje się skanowanie antywirusowe

- i weryfikację integralności konfiguracji.
- 10.6.2. Wszystkie hasła, klucze i certyfikaty związane z przywracaniem systemu są zmieniane.
- 10.6.3. System włącza się najpierw w trybie ograniczonym, z podwyższonym monitoringiem.
- 10.7. Weryfikacja poprawności danych. Jednostka operacji porównuje stan rachunków i rozliczeń z danymi sprzed incydu, ustala operacje wykonane w trakcie awarii oraz koryguje wszelkie nieprawidłowe księgowania. Korekty dokonuje się przez zapisy odwracające, z odniesieniem do numeru incydu.
- 10.8. Skutki finansowe dla Klientów. Jeżeli w wyniku incydu doszło do nieautoryzowanych transakcji na rachunkach Klientów, Bank zwraca kwotę nieautoryzowanej transakcji do końca następnego dnia roboczego po stwierdzeniu lub zgłoszeniu takiej transakcji, chyba że istnieją uzasadnione i udokumentowane podstawy podejrzewania oszustwa po stronie Klienta — o czym zawiadamia się właściwy organ. Zasady te wynikają z przepisów o usługach płatniczych — zob. ustawa z dnia 19 sierpnia 2011 r. o usługach płatniczych (Dz. U. 2024 poz. 30).
- 10.9. Zakończenie przywracania. Kierownik incydu zamyka fazę przywracania po łącznym spełnieniu warunków:
- 10.9.1. usługi działają stabilnie w uzgodnionym oknie obserwacji;
 - 10.9.2. przyczyna incydu została usunięta lub skutecznie zneutralizowana;
 - 10.9.3. dotknięci Klienci zostali poinformowani, a ich środki zabezpieczone;
 - 10.9.4. wszystkie wymagane zawiadomienia zostały przekazane.
- 10.10. Zamknięcie incydu. Incydent zamyka dyżurny Jednostki bezpieczeństwa po akceptacji kierownika incydu, uzupełniając Rejestr o datę i godzinę zakończenia, ostateczny poziom ważności, przyczynę źródłową i wartość strat.
- 10.11. Przegląd po incydencie. Dla każdego incydu o poziomie wysokim lub krytycznym oraz dla każdego incydu, który spowodował wyjątkowe skutki, Jednostka bezpieczeństwa wykonuje przegląd w terminie 10 dni od zamknięcia incydu.
- 10.11.1. W przeglądzie biorą udział kierownik incydu, członkowie Zespołu i przedstawiciele jednostek, których incydent dotyczył; spotkanie prowadzi osoba niezwiązana bezpośrednio z obsługą incydu.
 - 10.11.2. Przegląd ma charakter wyjaśniający, a nie wskazujący winnych; jego celem jest ustalenie, co zadziało, a co nie.
- 10.12. Zakres przeglądu. W przeglądzie bada się:
- 10.12.1. przyczynę źródłową i czynniki, które umożliwiły incydent;
 - 10.12.2. skuteczność wykrycia, czyli czas od początku incydu do jego wykrycia;
 - 10.12.3. skuteczność reakcji: czasy klasyfikacji, ograniczenia skutków i przywrócenia usług w porównaniu z wymaganiami;
 - 10.12.4. jakość komunikacji z Klientami, kierownictwem i podmiotami zewnętrznymi oraz dotrzymanie terminów zawiadomień;
 - 10.12.5. kompletność dokumentacji i materiału dowodowego.
- 10.13. Raport z przeglądu. Wyniki przeglądu opisuje się w raporcie według formularza

F-BEZ-05, który w ciągu 7 dni od przeglądu zatwierdza dyrektor Jednostki bezpieczeństwa. Raport o incydencie krytycznym przekazuje się Zarządowi.

- 10.14. Wnioski i zalecenia. Z przeglądu wynikają zalecenia z przypisanymi właścicielami i terminami. Zalecenia wprowadza się do wspólnego planu działań, a ich realizację monitoruje Jednostka zgodności; termin realizacji zaleceń nie powinien przekraczać 90 dni od zatwierdzenia raportu, chyba że Jednostka bezpieczeństwa zatwierdzi inny, uzasadniony termin.
- 10.15. Wykorzystanie wniosków. Wnioski z przeglądu wykorzystuje się do aktualizacji reguł systemu SIEM, scenariuszy ćwiczeń, szkoleń pracowników, planów ciągłości działania, ocen dostawców oraz niniejszej procedury.

Przywracanie działania systemów odbywa się w kolejności wynikającej z ich krytyczności dla Banku i klientów. Kolejność ustala Kierownik incydentu na podstawie analizy wpływu na działalność, z uwzględnieniem zależności technicznych.

- 10.16. Ustalenie kolejności przywracania.

- 10.16.1. W pierwszej kolejności przywraca się systemy niezbędne do realizacji płatności i autoryzacji transakcji klientów oraz systemy bezpieczeństwa.
- 10.16.2. W drugiej kolejności przywraca się kanały obsługi klientów: bankowość elektroniczną i aplikację mobilną, a następnie systemy placówek.
- 10.16.3. W ostatniej kolejności przywraca się systemy wspierające, takie jak raportowe i analityczne.

- 10.17. Warunki przywrócenia. System można ponownie udostępnić dopiero po spełnieniu wszystkich poniższych warunków:

- 10.17.1. przyczyna incydentu została usunięta albo skutecznie ograniczona, co potwierdził Zespół;
- 10.17.2. system został przetestowany pod kątem poprawności działania i integralności danych;
- 10.17.3. dostęp do systemu zostały sprawdzone, a podejrzane konta zlikwidowane;
- 10.17.4. właściciel systemu i Kierownik incydentu zatwierdzili przywrócenie na piśmie.

- 10.18. Stopniowe udostępnianie. Po przywróceniu system przez pierwsze godziny podlega wzmożonemu monitorowaniu, a o wszelkich anomaliach niezwłocznie informuje się Kierownika incydentu.

- 10.19. Rekonyliacja po incydencie. Po przywróceniu systemów Jednostka operacji wykonuje rekonyliację operacji dokonanych w okresie incydentu.

- 10.19.1. porównuje salda rachunków Klientów z zapisami w systemie centralnym i w systemach rozliczeniowych;
- 10.19.2. identyfikuje operacje zdublowane, utracone lub zaksięgowane z błędną datą;
- 10.19.3. przygotowuje listę korekt wraz z uzasadnieniem i przekazuje ją do akceptacji kierownika incydentu;
- 10.19.4. po wykonaniu korekt sporządza protokół z rekonyliacji, który dołącza się do dokumentacji incydentu.

- 10.20. Odsetki i opłaty. Gdy w wyniku błędu Klientowi naliczono opłaty lub odsetki, które nie

byłyby naliczone w braku incydentu, Bank je koryguje z urzędu, bez konieczności składania wniosku przez Klienta.

Odtwarzanie danych z kopii zapasowych jest jednym z podstawowych sposobów przywrócenia działania po incydencie. Zasady wykonywania i przechowywania kopii są określone w odrębnych dokumentach; poniższe zasady dotyczą postępowania w trakcie incydentu.

- 10.21. Wybór punktu odtworzenia. Właściciel systemu proponuje punkt odtworzenia, uwzględniając moment rozpoczęcia incydentu i dopuszczalną utratę danych.
 - 10.21.1. Wybiera się najpóźniejszy punkt sprzed rozpoczęcia incydentu, co do którego istnieje pewność, że nie zawiera złośliwego oprogramowania ani zmian dokonanych przez sprawcę.
 - 10.21.2. Jeżeli moment rozpoczęcia incydentu nie jest znany, odtwarzanie rozpoczyna się od testowania kolejnych, coraz starszych kopii.
- 10.22. Odtworzenie w środowisku odizolowanym. Dane odtwarza się najpierw w środowisku testowym, w którym weryfikuje się ich kompletność i integralność.
- 10.23. Uzgodnienie danych. Jednostka operacji uzgadnia salda i transakcje z okresu między punktem odtworzenia a chwilą incydentu, na podstawie dzienników, potwierdzeń kanałów płatniczych i dokumentów źródłowych.
- 10.24. Rejestr odtworzenia. Z odtworzenia danych sporządza się protokół, który zawiera datę, zakres, użyte kopie, wyniki weryfikacji oraz osoby odpowiedzialne.
- 10.25. Roszczenia i ubezpieczenie. Gdy incydent spowodował szkodę, która może być przedmiotem roszczenia wobec dostawcy, sprawcy lub ubezpieczyciela, Jednostka prawna:
 - 10.25.1. ustala dopuszczalne terminy zgłoszenia szkody i niezwłocznie je zachowuje;
 - 10.25.2. zbiera dokumentację niezbędną do dochodzenia roszczeń, korzystając z materiału dowodowego zabezpieczonego w trakcie incydentu;
 - 10.25.3. prowadzi korespondencję z ubezpieczycielem i dostawcą, uzgadniając jej treść z kierownikiem incydentu.
- 10.26. Ocena kar i sankcji. Jednostka zgodności sprawdza, czy incydent może skutkować nałożeniem sankcji przez organ nadzoru lub organ ochrony danych, i informuje o tym Zarząd wraz z propozycją działań ograniczających takie ryzyko.

11. Testy i ćwiczenia

Skuteczność procedury sprawdza się w praktyce poprzez regularne testy i ćwiczenia. Ich harmonogram na dany rok zatwierdza dyrektor Jednostki bezpieczeństwa do końca stycznia.

- 11.1. Testy planów reagowania. Plany reagowania na incydenty i plany odtwarzania systemów testuje się raz w roku. Test obejmuje co najmniej scenariusze: awarii systemu centralnego, ataku szyfrującego dane i niedostępności kluczowego dostawcy.
- 11.2. Ćwiczenia stołowe. Zespół uczestniczy w ćwiczeniach stołowych dwa razy w roku. W ćwiczeniu omawia się wymyślony scenariusz incydentu, role członków Zespołu, decyzje i komunikaty; z ćwiczenia sporządza się krótką notatkę z wnioskami.

- 11.3. Ćwiczenia praktyczne. Przynajmniej raz w roku wykonuje się ćwiczenie praktyczne z użyciem środowiska testowego lub kontrolowanej symulacji ataku, w którym sprawdza się działanie narzędzi wykrywania, kanałów powiadamiania i czasy reakcji.
- 11.4. Ocena wyników. Wyniki testów i ćwiczeń ocenia się według kryteriów: dotrzymanie czasów reakcji, kompletność powiadomień, poprawność decyzji oraz jakość dokumentacji. Stwierdzone nieprawidłowości traktuje się jak zalecenia po incydencie.

Poza ćwiczeniami organizacyjnymi Bank przeprowadza testy techniczne, które sprawdzają, czy mechanizmy wykrywania i reagowania działają zgodnie z założeniami.

- 11.5. Testy penetracyjne. Niezależny zespół, zewnętrzny lub wewnętrzny, wykonuje kontrolowane próby włamania do wybranych systemów, a zakres testów i zasady ich prowadzenia określa pisemne zlecenie.
 - 11.5.1. Zlecenie wskazuje systemy objęte testem, dozwolone techniki, okno czasowe oraz osoby kontaktowe, które mogą w każdej chwili przerwać test.
 - 11.5.2. Wyniki testów przedstawia się w raporcie z podziałem ustaleń według krytyczności i zaleceniem sposobu naprawy.
 - 11.6. Testy wykrywania. Jednostka bezpieczeństwa przeprowadza kontrolowane symulacje typowych ataków i sprawdza, czy system monitorowania wygenerował alert oraz czy analityk odpowiednio na niego zareagował.
 - 11.7. Kampanie sprawdzające czujność pracowników. Co najmniej raz w roku wysyła się pracownikom symulowane wiadomości wyłudzające dane i bada, ilu pracowników je otworzyło, kliknęło w odnośnik lub zgłosiło.
 - 11.7.1. Pracownicy, którzy ulegli symulowanej wiadomości, otrzymują natychmiast materiał szkoleniowy, a nie są karani.
 - 11.7.2. Wyniki prezentuje się w sposób zbiorczy, bez wskazywania osób.
 - 11.8. Usuwanie podatności. Podatności wykryte w testach usuwa się w terminach zależnych od ich krytyczności, a status usuwania podlega nadzorowi Jednostki bezpieczeństwa.
- Skuteczna obsługa incydentu wymaga sprawnej łączności z osobami, które mogą zostać do niej wezwane. Gotowość kanałów łączności sprawdza się regularnie, niezależnie od ćwiczeń scenariuszowych.
- 11.9. Test wezwania. Co kwartał Dyżurny przeprowadza próbne wezwanie członków Zespołu, wysyłając wiadomość i wykonując połączenia na numery z listy kontaktów alarmowych.
 - 11.9.1. Mierzy się czas, w jakim potwierdziły odbiór poszczególne osoby; za prawidłowy uznaje się wynik, w którym co najmniej 90% wezwanych potwierdziło odbiór w ciągu piętnastu minut.
 - 11.9.2. Osoby, które nie potwierdziły odbioru, są kontaktowane przez przełożonego w celu wyjaśnienia przyczyn i aktualizacji danych.
 - 11.10. Test kanałów zapasowych. Raz na pół roku sprawdza się działanie zapasowych kanałów łączności, w tym komunikatora poza infrastrukturą Banku i telefonów satelitarnych lub służbowych telefonów zapasowych.
 - 11.11. Test pokoju operacyjnego. Raz w roku sprawdza się, czy wirtualny pokój operacyjny

incydentu można uruchomić w ciągu godziny, czy ma dostęp do niego komplet uprawnionych osób oraz czy rejestruje wszystkie wpisy.

- 11.12. Wyniki testów. Wyniki testów łączności zapisuje się w rejestrze ćwiczeń, a zauważone nieprawidłowości usuwa się bez zbędnej zwłoki.
- 11.13. Szkolenia pracowników. Każdy pracownik przechodzi szkolenie z rozpoznawania i zgłaszania incydentów przy zatrudnieniu, w ciągu 30 dni, oraz powtarzają je co roku.
 - 11.13.1. Szkolenie obejmuje przykłady wiadomości wyłudzających dane, zasady zgłaszania zdarzeń oraz skutki zaniechania zgłoszenia.
 - 11.13.2. Członkowie Zespołu przechodzą dodatkowe szkolenie specjalistyczne obejmujące narzędzia, zasady zabezpieczania dowodów i komunikacji w czasie incydentu.
 - 11.13.3. Udział w szkoleniach rejestruje Jednostka kadr, a Jednostka bezpieczeństwa otrzymuje raport o osobach, które nie ukończyły szkolenia w terminie.

Ćwiczenia stołowe polegają na przeciwczeniu reakcji na scenariusz incydentu w formie dyskusji prowadzonej według przygotowanego scenariusza, bez faktycznego wpływu na działanie systemów. Są wykonywane co najmniej raz na dwa razy w roku.

- 11.14. Przygotowanie. Jednostka bezpieczeństwa wybiera scenariusz, ustala cele ćwiczenia i wyznacza prowadzącego, który nie jest uczestnikiem ćwiczenia.
 - 11.14.1. Uczestników powiadamia się z wyprzedzeniem, ale nie ujawnia się im szczegółów scenariusza.
 - 11.14.2. Przygotowuje się wstrzyknięcia, czyli informacje podawane uczestnikom w trakcie ćwiczenia, które zmieniają jego przebieg.
- 11.15. Przebieg. Prowadzący przedstawia uczestnikom sytuację początkową, a następnie w odstępach czasu podaje kolejne wstrzyknięcia.
 - 11.15.1. Uczestnicy opisują, jakie działania podjęliby w danym momencie i na podstawie jakich dokumentów.
 - 11.15.2. Obserwatorzy notują decyzje, trudności, nieporozumienia i luki w procedurach.
- 11.16. Podsumowanie. Bezpośrednio po ćwiczeniu odbywa się spotkanie, na którym omawia się obserwacje, a w ciągu tygodnia sporządza się raport ze wskazaniem zaleceń.
- 11.17. Wnioski. Zalecenia z ćwiczeń włącza się do planu działań naprawczych i realizuje na zasadach przewidzianych dla zaleceń z przeglądów incydentów.

12. Przypadki szczególne

Poniżej opisano sytuacje, w których postępowanie według zasad ogólnych wymaga modyfikacji. Pozostałe postanowienia procedury stosuje się odpowiednio.

Zasady wspólne dla przypadków szczególnych:

- 1) w przypadku wątpliwości co do tego, który tryb obowiązuje, stosuje się tryb bardziej rygorystyczny;
- 2) kierownik incydentu może odstąpić od kolejności czynności określonej w procedurze,

jeżeli wymaga tego ochrona Klientów lub ich środków; odstępnie i jego uzasadnienie odnotowuje w dzienniku zdarzeń;

3) w przypadku jednoczesnego wystąpienia kilku incydentów priorytet nadaje się według poziomu ważności, a przy tym samym poziomie — według liczby dotkniętych Klientów.

12.1. Utrata lub kradzież urządzenia służbowego. Pracownik, który utracił komputer, telefon, nośnik danych lub token, zgłasza to niezwłocznie dyżurnemu, nie później niż w ciągu 30 minut od stwierdzenia utraty.

12.1.1. Jednostka informatyki blokuje konta i certyfikaty powiązane z urządzeniem oraz, o ile to możliwe, zdalnie usuwa z niego dane.

12.1.2. Jednostka bezpieczeństwa ocenia, jakie dane mogły znajdować się na urządzeniu i czy były zaszyfrowane; wynik oceny jest podstawą decyzji o zgłoszeniu naruszenia ochrony danych.

12.1.3. Pracownik składa pisemne wyjaśnienie okoliczności utraty, a w przypadku podejrzenia przestępstwa — zawiadomienie na policję.

Incydent z udziałem pracownika, w szczególności podejrzenie nadużycia lub celowego działania na szkodę Banku, wymaga zachowania szczególnej poufności i ostrożności w ocenie faktów, aby chronić dobre imię osoby, której zdarzenie dotyczy.

12.2. Ograniczenie kręgu osób. Informacje o zdarzeniu przekazuje się wyłącznie osobom, które muszą je znać, a ich listę prowadzi Kierownik incydentu.

12.3. Zabezpieczenie dowodów. Jednostka bezpieczeństwa zabezpiecza dane i urządzenia, których dotyczy podejrzenie, w sposób niewzbudzający niepotrzebnej uwagi, ale zgodny z zasadami opisanymi w niniejszej procedurze.

12.3.1. Czynności wymagające wglądu w korespondencję lub dane pracownika wykonuje się wyłącznie w granicach dopuszczonych prawem i regulaminem pracy.

12.3.2. Zakres analizowanych danych ogranicza się do tych, które są niezbędne dla wyjaśnienia sprawy.

12.4. Udział Jednostki kadr. Jednostka kadr doradza w zakresie konsekwencji pracowniczych; decyzje w tej sprawie podejmuje się dopiero po zakończeniu analizy faktów.

12.5. Zawiadomienie organów. Jeżeli istnieje uzasadnione podejrzenie przestępstwa, zawiadomienie organów ścigania składa Zarząd na wniosek radcy prawnego.

12.6. Atak odmowy usługi. W razie ataku przeciążeniowego na kanały elektroniczne Jednostka informatyki:

12.6.1. uruchamia mechanizmy filtrowania ruchu i, w przypadku potrzeby, usługę ochrony udostępnioną przez operatora łączy;

12.6.2. przekierowuje ruch Klientów do zapasowych punktów dostępu, o ile takie istnieją;

12.6.3. zbiera dane o źródłach i charakterze ruchu na potrzeby analizy i zawiadomienia o przestępstwie.

12.7. Komunikacja podczas ataku. Jednostka komunikacji informuje Klientów o utrudnieniach w dostępie do bankowości elektronicznej i o możliwości skorzystania z placówek i infolinii. Komunikat nie obejmuje informacji o zastosowanych

zabezpieczeniach.

13. Kontrola i nadzór

Stosowanie procedury podlega kontroli w ramach systemu kontroli wewnętrznej Banku, zgodnie z wymogami wynikającymi z przepisów prawa bankowego — zob. ustawa z dnia 29 sierpnia 1997 r. – Prawo bankowe (Dz. U. 2024 poz. 1646).

1. Kontrola obejmuje:

- 1) kontrolę funkcjonalną, czyli bieżącą weryfikację kompletności wpisów w Rejestrze przez Jednostkę bezpieczeństwa (co miesiąc);
- 2) kontrolę Jednostki zgodności, czyli ocenę dotrzymywania terminów zawiadomień dla organów zewnętrznych (co kwartał);
- 3) audyt wewnętrzny, czyli niezależną ocenę adekwatności i skuteczności procedury, prowadzoną przez Jednostkę audytu zgodnie z planem audytów.

2. Wskaźniki monitorowane w ramach nadzoru nad procedurą to w szczególności:

- 1) liczba incydentów w podziale na poziomy ważności i kategorii;
- 2) średni czas wykrycia, klasyfikacji i zamknięcia incydentu;
- 3) odsetek incydentów, w których dotrzymano czasu pierwszej reakcji;
- 4) odsetek zawiadomień przekazanych w terminie;
- 5) liczba przeterminowanych zaleceń po incydentach.

Jednostka bezpieczeństwa przedstawia Zarządowi kwartalne sprawozdanie z incydentów, a w razie incydentu krytycznego — niezwłoczną informację. Nieprawidłowości stwierdzone w kontroli są podstawą do zaleceń, których wykonanie monitoruje Jednostka zgodności.

Jednostka bezpieczeństwa prowadzi wskaźniki ryzyka (KRI) dotyczące incydentów, dla których Zarząd ustala poziomy ostrzegawczy. Przekroczenie poziomu ostrzegawczego wymaga:

- 1) pisemnego wyjaśnienia przyczyn przez właściciela procesu;
- 2) planu działań naprawczych z terminami;
- 3) informacji w najbliższym sprawozdaniu dla Zarządu.

Wskaźniki obejmują m.in. liczbę incydentów krytycznych w kwartale, średni czas wykrycia, odsetek niedotrzymanych terminów zawiadomień oraz liczbę incydentów powtarzających się.

Raz w roku Jednostka bezpieczeństwa dokonuje samooceny poziomu rozwoju procesu obsługi incydentów, porównując go z uznanymi standardami zarządzania incydentami. Wyniki samooceny, wraz z wskazanymi obszarami do poprawy, przedstawia Zarządowi. Obszary do poprawy wprowadza się do planu działań na kolejny rok.

Poza samooceną Jednostka audytu ocenia w cyklu audytowym, czy procedura jest stosowana w całym Banku, w tym w oddziałach i jednostkach zależnych.

Jednostka zgodności raz na kwartał wykonuje kontrolę próbną, która obejmuje:

- 1) wybór losowej próby incydentów z Rejestru i sprawdzenie kompletności ich dokumentacji;
- 2) sprawdzenie, czy poziom ważności został nadany prawidłowo;
- 3) sprawdzenie dotrzymania terminów zawiadomień dla organu nadzoru i organu ochrony danych;
- 4) ocenę, czy zalecenia z przeglądu zostały zrealizowane.

Wyniki kontroli przedstawia się dyrektorowi Jednostki bezpieczeństwa, który odpowiada za usunięcie nieprawidłowości.

14. Dokumentacja i archiwizacja

Dokumentację incydentu tworzą: wpis w Rejestrze, karta incydentu (F-BEZ-02), dziennik zdarzeń z pokoju operacyjnego, protokoły zabezpieczenia dowodów (F-BEZ-04), kopie zawiadomień i korespondencji z organami zewnętrznymi oraz raporty z przeglądu (F-BEZ-05).

Dokumentację przechowuje się w następujący sposób:

- 1) w postaci elektronicznej, w systemie zgłoszeń i w repozytorium dokumentów Jednostki bezpieczeństwa, z dostępem ograniczonym do osób uprawnionych;
- 2) przez okres 10 lat od zamknięcia incydentu, a w przypadku toczących się postępowań — do ich prawomocnego zakończenia;
- 3) z zabezpieczeniem przed zmianą — poprawki wpisów dokonuje się przez dopisek, bez usuwania poprzedniej treści.

Po upływie okresu przechowywania dokumentację niszczy się w sposób uniemożliwiający jej odtworzenie, za zgodą Jednostki prawnej, a protokół zniszczenia dołącza się do ewidencji dokumentów. Dokumentacja zawierająca tajemnicę bankową może być udostępniona jedynie na zasadach określonych w przepisach prawa bankowego.

Dane osobowe Klientów wykorzystuje się wyłącznie w zakresie niezbędnym do realizacji zadań opisanych w procedurze, zgodnie z przepisami o ochronie danych osobowych (zob. ustawa z dnia 10 maja 2018 r. o ochronie danych osobowych (Dz. U. 2019 poz. 1781)) oraz z zasadą minimalizacji danych.

Pracownik wykonujący czynności objęte procedurą jest obowiązany:

- 1) zabezpieczać dokumenty i dane przed dostępem osób nieupoważnionych;
- 2) nie udostępniać danych poza Bank bez podstawy prawnej;
- 3) niezwłocznie zgłaszać każde podejrzenie naruszenia ochrony danych: inspektorowi ochrony danych (Inspektor Ochrony Danych) oraz jednostce bezpieczeństwa (Departament Bezpieczeństwa).

Wnioski osób, których dane dotyczą, przekazuje się do inspektora ochrony danych (Inspektor Ochrony Danych, iod@bank.example); odpowiedź jest udzielana bez zbędnej zwłoki, nie później niż w terminie miesiąca od dnia otrzymania wniosku.

15. Postanowienia końcowe

Procedura wchodzi w życie z dniem 1 marca 2024 r. i obowiązuje wszystkich pracowników Banku. Z tym dniem traci moc poprzednia wersja procedury obsługi incydentów.

Właścicielem procedury jest Departament Bezpieczeństwa, który przegląda jej treść przynajmniej raz w roku oraz po każdym incydencie krytycznym i po każdej zmianie przepisów lub wytycznych organu nadzoru wpływającej na jej treść.

Załączniki stanowią nierozdzielalną część procedury. Wzory formularzy wskazanych w procedurze udostępnia właściciel procedury w repozytorium dokumentów wewnętrznych.

Zmiany procedury wprowadza się w trybie przewidzianym dla jej pierwotnego przyjęcia. Projekt zmiany przygotowuje właściciel procedury, a opiniuje Departament Zgodności oraz, w razie potrzeby, Departament Prawny.

Każda zmiana musi zawierać:

- 1) wskazanie nowej wersji i daty jej wejścia w życie;
- 2) zwięzły opis zmienionych postanowień wraz z uzasadnieniem;
- 3) wzmiankę o konieczności przeszkolenia pracowników.

Poprzednie wersje archiwizuje się i udostępnia na żądanie komórki ds. zgodności (Departament Zgodności). Pracownicy są informowani o zmianie przed dniem jej wejścia w życie.

Kontakt z Klientem prowadzi się wyłącznie kanałami opisanymi w umowie lub w ustaleniach z Klientem. Dane teleadresowe Banku podawane w korespondencji muszą być zgodne z danymi: adres ul. Przykładowa 1, 00-001 Warszawa, infolinia 800 000 001, strona <https://bank.example>.

W rozmowie z Klientem pracownik:

- 1) przedstawia się i nazwę Banku;
- 2) potwierdza tożsamość Klienta metodą przewidzianą w procedurach bezpieczeństwa;
- 3) nie prosi o podanie haseł, kodów jednorazowych ani numeru PIN.

Sprawy wymagające eskalacji przekazuje się do jednostki właściwej (Departament Obsługi Klienta), a podejrzenia nadużyć — do jednostki bezpieczeństwa (Departament Bezpieczeństwa).

Załącznik nr 1

Macierz klasyfikacji incydentów i wzór karty incyduentu

Macierz pozwala przypisać incydent do poziomu ważności. Gdy incydent spełnia kryteria co najmniej dwóch poziomów, przyjmuje się poziom najwyższy.

Kryterium	Krytyczny	Wysoki	Średni
Liczba dotkniętych Klientów	ponad 1 000 Klientów	od 100 do 1 000 Klientów	mniej niż 100 Klientów
Czas niedostępności usługi	dłużej niż 2 godziny	od 30 minut do 2 godzin	krócej niż 30 minut
Potencjalna strata finansowa	powyżej 500 000,00 zł	powyżej 50 000,00 zł	poniżej 50 000,00 zł
Dane osobowe	ujawnienie danych o wysokim ryzyku lub danych szczególnych kategorii	ujawnienie danych zwykłych bez ryzyka wysokiego	brak ujawnienia
Pierwsza reakcja — do	15 minut	1 godziny	4 godzin
Obsługa	Zespół, powiadomienie członka Zarządu	Zespół, powiadomienie dyrektorów	dyżurny i właściwa jednostka

Incydent o poziomie niskim obsługuje dyżurny w czasie do 2 dni roboczych.

Wzór karty incyduentu

Karta incyduentu (F-BEZ-02) zawiera następujące pola:

Pole	Zawartość
Numer incyduentu	numer przypisany w Rejestrze
Data i godzina wykrycia	moment wykrycia oraz zgłoszenia
Zgłaszający	imię i nazwisko, jednostka, kanał zgłoszenia
Opis zdarzenia	co się stało, jakich systemów lub procesów dotyczy
Kategoria i poziom ważności	kategoria incyduentu, poziom nadany i ewentualne zmiany z godziną
Kierownik incyduentu	imię i nazwisko, skład Zespołu
Skutki	liczba Klientów, wartość operacji, czas niedostępności
Podjęte działania	chronologiczny wykaz czynności z godzinami
Zawiadomienia	adresaci, terminy, numery zawiadomień
Przyczyna źródłowa	ustalona przyczyna lub wzmianka o braku ustaleń
Zalecenia	zalecenia, osoby odpowiedzialne, terminy

Wykaz kontaktów alarmowych

Funkcja	Kontakt
Dyżurny Jednostki bezpieczeństwa	telefon 800 000 040, adres e-mail incydenty@bank.example
Inspektor	adres e-mail iod@bank.example
Infolinia dla Klientów	800 000 001 (codziennie przez całą dobę)
Zastrzeganie instrumentów płatniczych	800 000 002
Dyżurny Jednostki informatyki	numer służbowy zgodny z aktualnym harmonogramem dyżurów
Organ nadzoru	kanał wyznaczony przez organ nadzoru dla zawiadomień o incydentach poważnych

Wzór wpisu w dzienniku zdarzeń incyduentu

Dziennik zdarzeń prowadzi się chronologicznie. Każdy wpis składa się z poniższych elementów, a wpisów nie usuwa się; błędny wpis prostuje się kolejnym wpisem.

1. Data i godzina wpisu oraz data i godzina opisywanego zdarzenia, jeżeli się różnią.
2. Autor wpisu oraz jego rola w obsłudze incyduentu.
3. Treść wpisu: ustalony fakt, podjęta decyzja albo wykonana czynność.
4. Podstawa: dokument, dziennik systemu lub osoba, od której pochodzi informacja.
5. Zlecone działania: kto ma coś zrobić i do kiedy.

Zestawienie czasów reakcji według klasyfikacji

Klasyfikacja	Czas reakcji	Osoba decydująca
Krytyczna	15 minut	Kierownik incyduentu i członek Zarządu
Wysoka	1 godziny	Kierownik incyduentu
Średnia	4 godzin	Analitik bezpieczeństwa
Niska	2 dni roboczych	Dyżurny

Czas reakcji liczy się od chwili zaklasyfikowania incyduentu albo od chwili podwyższenia jego klasyfikacji.

Załącznik nr 2

Lista kontrolna obsługi incydentu

Listę wypełnia kierownik incydentu (lub dyżurny — dla incydentów średnich i niskich) i dołącza do karty incydentu.

- ☐ Zgłoszenie zarejestrowane w Rejestrze i potwierdzone osobie zgłaszającej.
- ☐ Poziom ważności nadany w ciągu 2 godzin od zgłoszenia.
- ☐ Wyznaczono kierownika incydentu; w razie potrzeby powołano Zespół.
- ☐ Otwarto pokój operacyjny i prowadzony jest dziennik zdarzeń.
- ☐ Zabezpieczono materiał dowodowy, a protokół F-BEZ-04 wypełniono.
- ☐ Podjęto działania ograniczające skutki, a ich wpływ na Klientów oceniono.
- ☐ Jednostka zgodności i Inspektor ocenili obowiązki wobec podmiotów zewnętrznych.
- ☐ Zawiadomienie wstępne dla organu nadzoru przekazano w terminie 6 godzin (jeżeli dotyczy).
- ☐ Naruszenie ochrony danych zgłoszono w terminie 72 godzin (jeżeli dotyczy).
- ☐ Klientów poinformowano w terminie 24 godzin (jeżeli dotyczy).
- ☐ Usunięto przyczynę, a usługi przywrócono i zweryfikowano.
- ☐ Skorygowano błędne księgowania i zwrócono nieautoryzowane transakcje.
- ☐ Zawiadomienie pośrednie i raport końcowy przekazano w terminach (jeżeli dotyczy).
- ☐ Przegląd po incydencie przeprowadzono w terminie 10 dni, a zalecenia wpisano do planu działań.
- ☐ Incydent zamknięto w Rejestrze.